

# Vendor Risk Assessment Framework

*Policy Document | StubHub Third-Party Risk Program | GRC Function*

## Document Control

| Field          | Value                                                      |
|----------------|------------------------------------------------------------|
| Document Owner | GRC Analyst, Third-Party Risk Management                   |
| Approved By    | Chief Information Security Officer (CISO)                  |
| Effective Date | July 5, 2026                                               |
| Review Cycle   | Annual, or upon material change to vendor risk environment |
| Version        | 1.0                                                        |

## 1. Framework Scope Statement

This Vendor Risk Assessment Framework applies to all third-party vendors, suppliers, and service providers that access, process, store, or transmit StubHub customer data, or that provide services critical to platform availability including payment processors (e.g., Stripe, Adyen, Braintree), cloud infrastructure providers (e.g., AWS, GCP), marketing and analytics platforms (e.g., Salesforce, Segment, Adobe), ticketing technology integration partners, and staffing or professional services firms with system access. The framework addresses cybersecurity, data privacy, operational resilience, and regulatory compliance risk, with particular emphasis on PCI DSS relevance for payment vendors and availability risk for infrastructure vendors. Ownership of this framework and the vendor risk lifecycle it governs sits with the Governance, Risk, and Compliance (GRC) function, with required input and sign-off from Legal, Procurement, and Engineering at defined checkpoints in the vendor lifecycle.

## 2. Vendor Landscape Covered

The vendor population in scope spans five primary categories, each carrying a distinct risk profile that this framework is designed to differentiate:

| Category                         | Representative Examples       | Primary Risk Concern                     |
|----------------------------------|-------------------------------|------------------------------------------|
| Payment Processors               | Stripe, Adyen, Braintree      | High data sensitivity; PCI DSS relevance |
| Cloud Infrastructure             | AWS, GCP                      | Availability and resilience risk         |
| Marketing & Analytics            | Salesforce, Segment, Adobe    | Customer PII exposure                    |
| Ticketing Technology Partners    | Integration vendors           | IP and integration risk                  |
| Staffing & Professional Services | Contract and consulting firms | Insider threat and access risk           |

### 3. Vendor Tiering Model

Vendors cannot be assessed with uniform depth risk management resources are finite and must be directed where exposure is greatest. This framework sorts every vendor into one of three tiers based on two axes: data sensitivity and operational criticality. Tier assignment determines assessment frequency and questionnaire depth. The full tiering criteria and vendor inventory live in **VRA-Tiering-Model.xlsx**; the summary below is the policy-level reference.

| Tier | Label    | Data Sensitivity                                  | Operational Criticality                            | Assessment Frequency     | Questionnaire Depth        |
|------|----------|---------------------------------------------------|----------------------------------------------------|--------------------------|----------------------------|
| 1    | Critical | Processes PII, PCI, or PHI data at scale          | Outage causes direct revenue loss or customer harm | Annual + event-triggered | Full (60+ questions)       |
| 2    | High     | Limited PII access or non-core data processing    | Outage degrades service but workarounds exist      | Annual                   | Standard (30 questions)    |
| 3    | Low      | No data access or anonymised/aggregated data only | Outage has minimal customer-facing impact          | Every 2 years            | Lightweight (15 questions) |

#### Tiering Decision Tree

Used by the analyst at vendor intake to assign a tier before any assessment begins:

Q1: Does the vendor access, store, or process customer PII or payment data?

YES → Tier 1

NO → Go to Q2

Q2: Would a vendor outage or breach directly impact StubHub's ability to sell or deliver tickets?

YES → Tier 2

NO → Go to Q3

Q3: Does the vendor have any network access to StubHub systems or data, even indirectly?

YES → Tier 2

NO → Tier 3

### 4. Vendor Security Scoring Methodology

Each questionnaire response is scored using a weighted model. Every question carries a Risk Weight (1–3) reflecting its security significance. Responses are converted to a Score Multiplier: Yes = 1.0, Partial = 0.5, No = 0.0, N/A = 1.0 (excluded from the denominator). The raw score

per question equals Risk Weight × Score Multiplier. All raw scores are summed and divided by the maximum possible score, then multiplied by 100 to produce a Vendor Security Score out of 100. Full question banks and the scoring key are maintained in **VRA-Questionnaire.xlsx**.

## 5. Risk Acceptance and Escalation Criteria

A numeric score is only useful if it drives a decision. The ratings below translate Vendor Security Scores into required actions for onboarding, ongoing management, and escalation.

### **CRITICAL (Score 0–49)**

- Cannot onboard vendor without CISO sign-off
- Existing vendors must have a remediation plan within 30 days
- Escalate to Legal and Procurement immediately
- Re-assess within 90 days of remediation completion

### **HIGH (Score 50–69)**

- Onboarding requires GRC Analyst sign-off and documented compensating controls
- Existing vendors must remediate within 90 days
- Monthly check-in with vendor on remediation progress

### **MEDIUM (Score 70–84)**

- Standard onboarding proceeds with documented findings
- Remediation tracked in risk register, due within 180 days
- Findings reviewed at next annual assessment

### **LOW (Score 85–100)**

- Standard onboarding with no additional conditions
- Findings (if any) logged for awareness only
- Next review per standard tiering schedule

## 6. Risk Acceptance Statement Template

When a business owner elects to proceed with a vendor despite known risk, the following statement is completed, signed, and filed alongside the vendor's risk register entry.

Vendor Name: \_\_\_\_\_

Risk Rating: \_\_\_\_\_

Known Risks: \_\_\_\_\_

I, the undersigned, accept the residual risk associated with engaging this vendor and confirm that compensating controls are in place as documented in the risk register.

Business Owner Signature: \_\_\_\_\_

Date: \_\_\_\_\_

GRC Analyst: \_\_\_\_\_

*By signing above, the Business Owner accepts the residual risk associated with engaging this vendor and confirms that compensating controls are in place as documented in the risk register.*

## 7. Governance and Roles

| Role           | Responsibility                                                                                                                      |
|----------------|-------------------------------------------------------------------------------------------------------------------------------------|
| GRC Analyst    | Owns the vendor risk lifecycle end to end: tiering, questionnaire distribution, scoring, risk register maintenance, and escalation. |
| CISO           | Approves onboarding of Critical (Tier 1) vendors and any vendor scoring in the Critical risk band.                                  |
| Legal          | Reviews contractual risk transfer language (indemnification, breach notification, right-to-audit) for Tier 1 and Tier 2 vendors.    |
| Procurement    | Ensures vendor risk assessment is completed before contract execution; enforces re-assessment triggers at renewal.                  |
| Engineering    | Provides technical input on integration risk and validates vendor security controls where system access is granted.                 |
| Business Owner | Signs Risk Acceptance Statements for vendors onboarded with open findings and owns remediation follow-through.                      |

## 8. Review and Maintenance

This framework is reviewed annually by the GRC function, or immediately following a material vendor-related incident, a change in applicable regulation (e.g., PCI DSS revision, new state privacy law), or a significant shift in StubHub's vendor risk environment. Updates are version-controlled and communicated to Legal, Procurement, and Engineering stakeholders.